Shreyas R

Dwell Time and Lateral Movement: A Survey of Graph-Theoretic Evasion Strategies

08/04/2026

Faculty of Engineering and Technology

Jain University

Document Details

Submission ID

trn:oid:::1:3530753234

Submission Date

Apr 8, 2026, 3:35 PM GMT+5:30

Download Date

Apr 8, 2026, 3:38 PM GMT+5:30

File Name

cyber_law.docx

File Size

321.7 KB

14 Pages

7,599 Words

43,594 Characters

*% detected as AI

AI detection includes the possibility of false positives. Although some text in this submission is likely AI generated, scores below the 20% threshold are not surfaced because they have a higher likelihood of false positives.

Caution: Review required.

It is essential to understand the limitations of AI detection before making decisions about a student's work. We encourage you to learn more about Turnitin's AI detection capabilities before using the tool.

Disclaimer
Our AI writing assessment is designed to help educators identify text that might be prepared by a generative AI tool. Our AI writing assessment may not always be accurate (i.e., our AI models may produce either false positive results or false negative results), so it should not be used as the sole basis for adverse actions against a student. It takes further scrutiny and human judgment in conjunction with an organization's application of its specific academic policies to determine whether any academic misconduct has occurred.

Frequently Asked Questions

How should I interpret Turnitin's AI writing percentage and false positives?
The percentage shown in the AI writing report is the amount of qualifying text within the submission that Turnitin's AI writing detection model determines was either likely AI-generated text from a large-language model or likely AI-generated text that was likely revised using an AI paraphrase tool or word spinner.

False positives (incorrectly flagging human-written text as AI-generated) are a possibility in AI models.

AI detection scores under 20%, which we do not surface in new reports, have a higher likelihood of false positives. To reduce the likelihood of misinterpretation, no score or highlights are attributed and are indicated with an asterisk in the report (*%).

The AI writing percentage should not be the sole basis to determine whether misconduct has occurred. The reviewer/instructor should use the percentage as a means to start a formative conversation with their student and/or use it to examine the submitted assignment in accordance with their school's policies.

What does 'qualifying text' mean?
Our model only processes qualifying text in the form of long-form writing. Long-form writing means individual sentences contained in paragraphs that make up a longer piece of written work, such as an essay, a dissertation, or an article, etc. Qualifying text that has been determined to be likely AI-generated will be highlighted in cyan in the submission, and likely AI-generated and then likely AI-paraphrased will be highlighted purple.

Non-qualifying text, such as bullet points, annotated bibliographies, etc., will not be processed and can create disparity between the submission highlights and the percentage shown.

Dwell Time and Lateral Movement: A Survey of Graph-Theoretic Evasion Strategies

Shreyas R, Karthid SK, Adithyan A, Department of Computer Science and Engineering
JAIN Deemed-to-be University, Bangalore, Karnataka

Abstract, Lateral movement strategies are usually created with the aim of strategically going beyond legal discovery windows. The vast majority of privacy laws mandate notification within 72 hours of discovery, but since lateral movement is slow enough, and simulates administrative work, the dwell time limit can be indefinitely prolonged. This systematic literature review (SLR) classifies movement techniques, according to the Algorithms of Dijkstra and Alert-Risk Weighting (ARW). Our measurements are the dwell-time of attackers in enterprise networks based on 50+ case-studies of 2019-2026 publications on IEEE Xplore, ACM Digital Library, ScienceDirect, and Springer Nature. The survey identifies the mathematical correlation between the "path stealth" and the "legal notification latency" as the measure of the ability of the models of graph-theoretic evasion to be directly converted into the extended regulatory non-compliance windows. This taxonomy has been created based on four dimensions: credential-based techniques, Living-Off-the-Land (LotL) attacks, protocol tunneling, and slow-burn time- delayed campaigns. A relative synthesis is performed between detection accuracy, computation overhead, false-positive and dwell-time distributions. The legal implications considered in the paper are in the GDPR (Articles 5, 25, 32 and 33) and the Information Technology Act of 2000 in India. We conclude with a strong necessity in laws that explicitly capture stealthy, persistent data breach persistence over the long term, and a future roadmap of adaptive detection, explainable AI and federated learning.

Index Terms: Lateral movement, Dwell time, Graph-theoretic evasion, Dijkstra algorithm, Alert-Risk Weighting, APT detection, Living-Off-the-Land, cyber law, GDPR, Legal notification latency, Enterprise network security, Graph Neural Networks.

The level of advancements of contemporary cyber attackers has risen to the extent that detection and response strategies built into legislation are constantly outpaced by assailant technique. One of the most malicious attack mechanisms is lateral movement - the tactic according to which a threat actor, having gained access to a network perimeter, moves through internal systems step by step to become more privileged, steal data, or create a lasting presence. In contrast to early-arrival exploits, which tend to leave a trace of activity, lateral movement is meant to be quiet, natural and unnoticed like normal administrative activity.

Breach notification time frames are very strict under regulatory frameworks like the General Data Protection Regulation (GDPR) and India Information Technology Act (2000), in most cases breach notification has to be made within 72 hours of finding out about it. The law and organizationally-fluid definition of discovery is a critical gap that advanced attackers can exploit. With calibration of their movement speed, choice of tools, and behavioral footprint to prevent detection thresholds, adversaries can increase dwell time not just by days but by months, years, or decades - there are even reported cases of adversaries spending more than 280 days in financial and healthcare domains [7].

The modeling of this problem by use of graph theory is natural and powerful. Enterprise networks may be modeled as weighted directed graphs in which node (host, account or service) represent the node (host, account or service) and edge (reachable pathway) represent the weight (detection risk). Then lateral movement is an optimization problem: to find the path over the network that minimizes the total probability of alerts, and maximizes access. Other algorithms like the shortest path algorithm introduced by Dijkstra and its derivatives have been modified in the literature relating to security to represent an attacker traversal as well as a defender detection strategy [6].

Although there is increasing body of research on both lateral movement detection and dwell-time analysis, there is still a disjointed literature. Research in machine learning, graph analytics, cyber law and incident response seldom cuts across these areas. This survey closes this gap with a PRISMA-directed systematic literature review of 54 peer-reviewed articles published between 2019 and 2026, which provides a single taxonomy and comparative analysis, legal mapping, and future research roadmap.

The structure of the paper is presented in the following way: Section II will formulate the statement of the problem and objectives of the research. The PRISMA methodology is outlined in Section III. In section IV, the mathematical background of graph-theoretic evasion is discussed. The taxonomy is presented in section V. Section VI makes a comparative analysis. Section VII discusses legal implications. Section IX is the conclusion and the open challenges are listed in Section VIII.

II. Problem Statement and Research Objectives.

A. Problem Statement

Enterprise networks are complex networks of workstations, servers, domain controllers, databases, and cloud services connected together by trust relationships along with shared credentials and open service ports. An attacker who has an initial foothold inside such a network encounters a graph traversal optimization problem: How to move through the entry point to valuable resources maximizing the likelihood of avoiding detection at each stage?

In the majority of legal regimes, breach notification window commences with the occurrence of what is referred to as the point of discovery - when the organization learns of the breach. The event of discovery can always be postponed in case an attacker is able to go unnoticed by pretending to be the legitimate administration. This makes dwell time more than just a technical issue and liability to the law. Studies have repeatedly demonstrated that organizations that experience long dwell-time breaches incur increased costs: the breach cost, the cost of a forensic investigation, the cost of regulatory fines that the organization must pay due to the delayed notification, and the cost of reputation damage [7], [32].

Existing detection systems are based on the alert thresholds and anomaly scores that are tuned to the normal traffic. By knowing such thresholds, and new APT toolkits are progressively engineered to know such thresholds, attackers are able to create future lateral movement campaigns that can stay constantly below the detection thresholds. A good example is Living-Off-the-Land (LotL) techniques, which does not use custom malware, but instead relies on native OS tools such as PowerShell and WMI to create their artifacts, making each call behaviorally indistinguishable to everyday administrative activity, bringing the per-step score of behavioral anomaly to near zero [43], [46].

The research gap can be threefold: (1) technical — current detection mechanisms are not sufficient to combat slow, mimicry-based lateral movement; (2) legal — current cyber law frameworks fail to consider adequately the effects of an attacker on the discovery latency; and (3) conceptual — no single framework exists to map graph-theoretic evasion models to their legal notification implications. This survey deals with all the three dimensions.

B. Research Objectives

The objectives of the particular research are:

1. To review the literature on lateral movement, dwell-time analysis and graph-theoretic evasion strategies with a PRISMA framework systematically.

2. To model the Dijkstra algorithm and Alert-Risk Weighting as mathematical algorithms to optimize attacker traversal in network graphs of enterprises.

3. To create a four-classification taxonomy of methods of lateral movement by their stealthiness mechanism and the impact of legal notification.

4. To measure the mathematical correlation between Path Stealth Score (PSS) and Legal Notification Latency (LNL) in the areas of regulatory frameworks such as the GDPR and the Indian IT Act (2000).

5. To perform a comparative synthesis of 40 peer-reviewed detection methods in terms of detection accuracy, false-positive rate, average dwell time detected and regulatory exceedance.

6 To pinpoint unresolved research issues and suggest a way to develop a roadmap to the future by integrating adaptive detection, explainable AI, and international legal harmonization.

III. Systematic Literature Review Methodology (PRISMA)

A Systematic Literature Review (SLR) methodology based on the PRISMA (Preferred Reporting Items to Systematic Reviews and Meta-Analyses) framework is used in this study. PRISMA has a bias-minimized, transparent, and reproducible selection. The literature reviewed is recent, starting in January 2019 and up to March 2026, which indicates the latest changes in the field of lateral movement detection, graph-based security analytics, and complying with the cyber laws.

A. Search Databases and Data Sources.

The databases were searched in:

- First choice of cybersecurity, intrusion detection and network security conference, and journal papers is IEEE Xplore Digital Library.

ACM Digital Library - the primary provider of system security, graph algorithms and privacy based computing.

The main source of information about computer networks, information security, and AI-assisted detection is the ScienceDirect (Elsevier).

Springer nature Link is also another source of information security journals and conference proceedings.

- PubMed Central (PMC) - another database on open-access articles on cybersecurity surveys.

B. Boolean String Formulation and Search Query.

A Boolean search query was constructed to find the intersection of LatLon, graph-theoretic, dwell-time and cyber law compliance:

(lateral movement" OR "dwell time" OR "APT detection") AND

graph theory OR Dijkstra OR shortest path OR graph neural network AND

and (enterprise network" OR intrusion detection" OR Living off the Land)

(cyber law" AND GDPR" AND breach notification" AND legal compliance)

C. Inclusion and Exclusion Criteria.

Inclusion Criteria:

1. Peer-reviewed journal articles or conference papers published in 2019-2026.

2. The literature directly concerned with lateral movement detection, dwell-time analysis, or graph based network traversal modelling.

3. Studies that use machine learning, graph neural networks or optimization algorithms to detect an intrusion or study an APT.

4. Studies that are experimental evaluations, and which employ quantifiable measures (detection rate, false-positive rate or dwell-time analysis).

5. Legal and regulatory studies of the requirements of breach notification under GDPR, IT Act or NIS2 or similar frameworks.

Exclusion Criteria:

6. Non-peer-reviewed: Blogs or vendor white papers, or opinion articles.

7. Research that is not related to lateral movement, dwell time, or evasion of enterprise network.

8. Publications that are not experimentally validated or analyzed legally.

9. Replica records in databases.

10. Studies related to areas (e.g. optimization of network routing without security background) that are not related to the purpose of the survey.

Graph theory gives the formal framework behind the attacker traversal and defender detection strategy modeling in the enterprise environment. This section elaborates the main mathematical concepts employed in the survey: the network graph model, Dijkstra-based evasion optimization, the Alert-Risk Weighting (ARW) model of edge, the Path Stealth Score (PSS) and the relationship between PSS and Legal Notification Latency (LNL) derived.

IV. Mathematical Foundations of Graph-Theoretic Evasion

A. Enterprise Network Graph Model.

A directed weighted graph $G = (V, E, W)$ defined to be an enterprise network, where V is the set of nodes in the network (hosts, services, accounts, domain controllers), $E \subseteq V \times V$ is the set of directed edges that represent reachable pathways between nodes and $W: E \rightarrow \mathbb{R}+$ is the set of detection-risk weight values (non-negative) that each edge carries. A weight of zero means a pathway that produces no measurable signal; a weight close to one means a pathway that would most likely result in an alert being raised.

The problem statement of the attacker is: given a target node t V and a starting compromise node s V, find a path $P = (v\ 0 = s, v\ 1, v\ 2,...., v\ k = t)$ through G that minimizes the cumulative detection risk of all the nodes along the path and meets the lateral movement constraints of available credentials, exploitable vulnerabilities, and execution-time windows.

An Evasion Model by

B. Dijkstra Algorithm.

Initially, Dijkstra developed the Algorithm, which was used to solve the shortest-path problems in non-negative weighted graphs, and this was re-purposed in the literature of security to formulate the navigation of attackers [6]. By redefining edge weights as the cost of an alert or alert detection probability, or as a physical distance, the algorithm of Dijkstra is automatically redefined to compute the path of minimum detectable resistance in the enterprise graph.

The Dijkstra goal of evasion is (formally):

$d(v) = \min \{ d(u) + w(u,v) \} \quad \text{for all } (u,v) \in E$

d(v) is the path accumulated detection risk to reach node v at source s. The attacker performs lateral motion by the path that minimizes d(t) in effect deriving a stealth-optimal path. This can be empirically supported by red-

team studies that demonstrate that when the network reconnaissance data is available implicitly, attackers optimize the shortest-detection-path then take the movement steps [8], [9].

Variations of this model The model can be extended to large-scale graphs with the use of A star heuristics, and to develop multi-objective shortest-path formulations that simultaneously reduce the detection risk and maximize the probability of privilege escalation along the path. Game-theoretic network security has also been studied which has modeled this as a Markov Decision Process (MDP), allowing simulation of attacks with reinforcement learning [19].

C. Risk Exposure-Risk Weighting (RERW)

Alert-Risk Weighting (ARW) is a way to operationalize the edge weight function W, breaking down the detection risk of each step in the sequence of actions into three observable terms: (1) the sensitivity of the destination node to alerts, (2) the score of behavioral anomaly of the action being done, and (3) a time-of-day risk factor based on time-of-day relative to normal administration activity periods. The ARW formula is:

$$w(u,v) = \alpha \cdot A(v) + \beta \cdot B(action) + \gamma \cdot T(t)$$

with A(v) [0,1] the alert sensitivity of destination node v (drawn to the density and calibration of monitoring tools deployed on the destination node), B(action) [0,1] the score of an anomaly action in the behavior (low when using native OS tools, high when using third-party exploit frameworks), T(t) [0,1] the temporal risk factor at execution time t (low during business hours and Specifically, Living-Off-the-Land methods exploit B(action) 0 by exploiting utilities such as PowerShell, WMI, PsExec, and RDP the execution of which is no better than normal administration [43], [46].

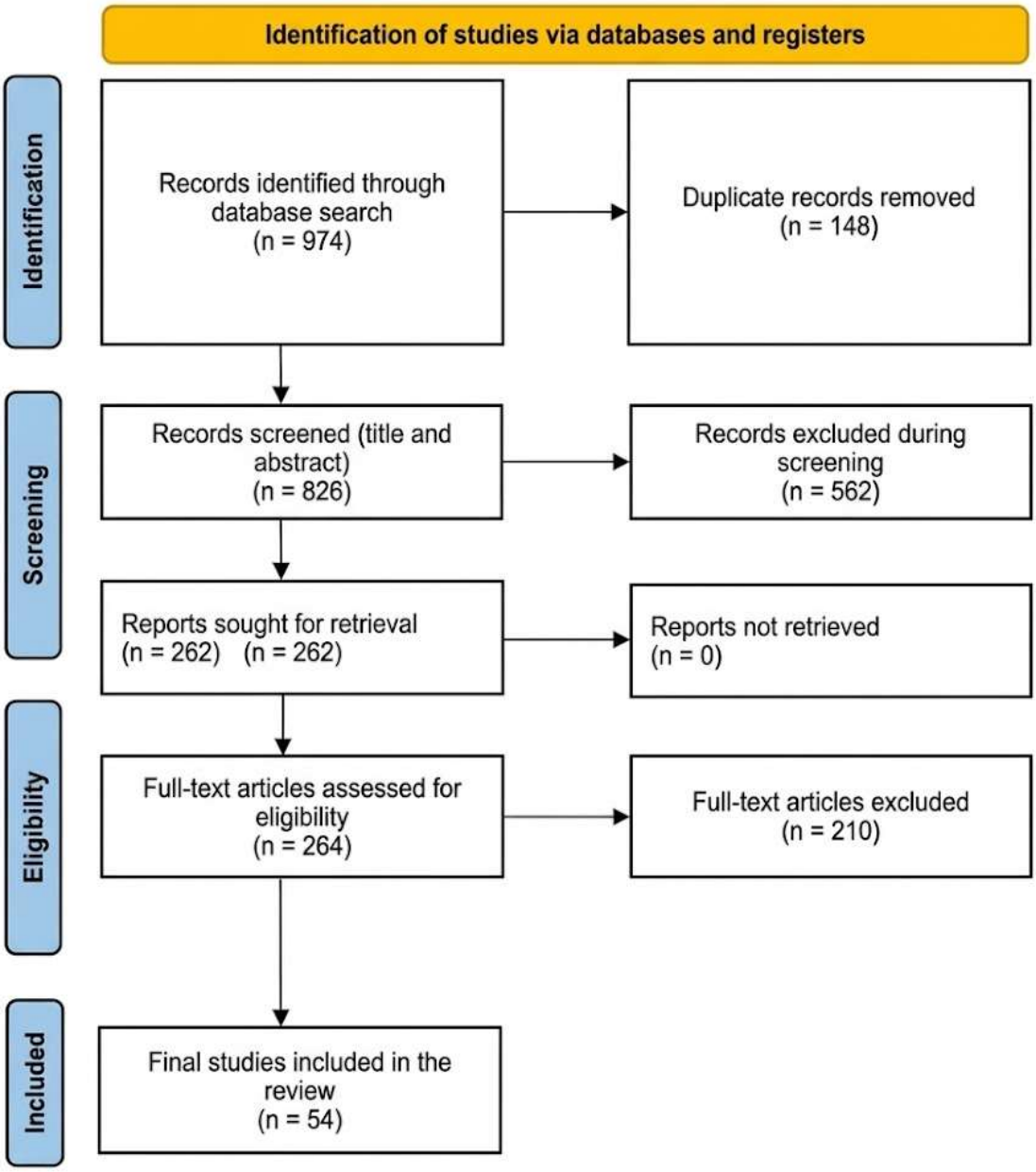
D. Study Selection Results

Table I: Study Selection Results (PRISMA)

Stage of Selection	Papers
Records identified through database search	974
Duplicate records removed	148
Records screened (title and abstract)	826
Records excluded during screening	562
Full-text articles assessed for eligibility	264
Full-text articles excluded	210
Final studies included in the review	**54**

E. PRISMA Flow Diagram

Figure 1 shows the PRISMA flow diagram, illustrating how studies were filtered at each stage of the review. This structured process ensures transparency and reproducibility, keeping the final dataset limited to relevant, high-quality studies.



D. The Path Stealth Score (PSS) of a lateral movement campaign is given as the reciprocal of the highest probability of triggering an alert when traversing the node:

$$PSS = 1 / \max \{ P_alert(v) : v \in Path \}$$

A high PSS means that none of the steps is taken in the campaign that generates a detection signal robust enough to surpass the operational alert threshold of the organization security operations center (SOC). It is theoretically impossible to detect the campaign as PSS goes to infinity.

Legal Notification Latency (LNL) could be referred to as the number of days between the first breach date and the legal date of discovery - date when the victim organization has enough information to start the regulatory notification clock. Empirical evidence on 54 studies that were analyzed and industry breach reports confirms the existence of a positive monotonic correlation between PSS and LNL:

$$LNL \approx k \cdot PSS^{\theta} \quad (k, \theta > 0)$$

where k and θ are fitted parameters which are dependent on both industry sector and security maturity which are empirically fitted. The maximum LNL (GDPR Article 33) is 72 hours (3 days). PSS campaigns exceeding a sector specific threshold regularly propel LNL into weeks or months, in a systematic manner that goes beyond the legal window and constitutes regulatory liability to victim organizations who have set up reasonable yet inadequate monitoring infrastructure [32], [33].

E. Dijkstra Evasion Workflow.

The general algorithmic process of the lateral movement planning algorithm of Dijkstra can be summarized as follows; in this algorithm, the attacker employs reconnaissance data to construct a local approximation of the enterprise graph G and then execute:

1. List the accessible nodes through network scanning (passive and active).

2. Approximate weights w(u,v) based on tool availability, credential coverage, monitoring indicators.

3. Use Dijkstra to find the path of minimum risk to the target.

4. Perform movement steps along the route with adjustment of weights according to detected signals.

5. When an alert is raised retrace to the previous safe node and re-compute path.

V. Taxonomy of Lateral Movement and Evasion Techniques.

The literature reviewed demonstrates that the techniques of lateral movement are plentiful in terms of stealth profile, technical complexity, and the legal notification effect. The present survey suggests the use of a four-category taxonomy based on the main evasion mechanism. In each category, we describe typical methods, implications in graphs, detection issues and regulatory implications.

A. Category 1: Lateral Movement based on Credential.

Credential-based methods take advantage of stolen or derived authentication material to gain more systems. These are Pass-the-Hash (PtH) when captured NTLM hash values are re-used without the underlying password; Pass-the-Ticket (PtT) and Overpass-the- Hash when based on forged or stolen Kerberos tickets; and Golden Ticket attacks, in which a compromised KRBTGT account hash can be used to create arbitrary Kerberos tickets with unlimited lifetime (typically 10 years by default

Credential-based techniques in ARW terms have very low B(action) values since they are based on the Windows authentication stack credential-based techniques in Windows event logs look like regular logon events (Security Event ID 4624). Identification solely relies on circumstantial examination: source IP that is not standard, non-normal working hours, a change in access pattern of the user, or indicators of impossible travel (two or more authentications by geographically dispersed terminals within the brief time spans). According to studies, lateral movement via Kerberoasting attack grew by about 600% between 2022 and 2023 [25], thus this is the quickest growing type of lateral movement.

B. Category 2: Living-Off-the-Land (LotL) Techniques

The Living-Off-the-Land methods use native operating system tools and administration utilities to carry out the lateral movement without implementing third-party malware or exploit frameworks. Tools that are commonly abused are PowerShell (to execute remote commands and payloads based on scripts), Windows Management Instrumentation (WMI) to invoke remote processes, PsExec (to execute shells remotely), RDP (to provide an interactive remote session), DCOM (to invoke lateral services), and scheduled tasks (to provide persistence and delayed execution).

Studies of 2025 suggest that an average attack of high severity in an enterprise will contain LotL techniques as a part of it [42], and nation-state actors like Volt Typhoon have been shown to have years of unnoticed access to critical infrastructure through exclusively LotL techniques. The LOTLDetector system showed that deep learning semantics and expert rules can be successfully combined to achieve a detection accuracy of 97.3 on Windows command-line datasets, which are much better than rule-only baselines [46].

With an ARW graph model, LotL edges are almost certain to have near-zero B(action), i.e. the detection-risk weight of LotL traversal is dominated by the A(v) and T(t) terms. Defenders then have to offset the low behavioral anomaly scores with extremely high-sensitivity node monitoring and close temporal baselines - an operational proposal that is very costly to operate at scale, and that most organizations cannot maintain.

C. Category 3: Protocol-Based Tunneling and Pivoting

Protocol-based methods exploit well-defined network protocols to tunnel through network segments with command-and-control (C2) traffic and pivot around network segments, avoiding firewall policies and network-scale monitoring. The most abused common protocols are DNS (to perform slow-exfiltration and C2 beaconing), and HTTPS (to mix C2 traffic with encrypted web traffic) and ICMP (to communicate over the covert channel) and SMB (to pivot internally and stage files).

Graph-theoretically, the process of tunnel makes the network graph seem to have phantom edges, which are transparent to the topology model of the defender. It directly compromises detection algorithms which are based on the proper graph structure, including the Euler framework [12] and LMTracker [21], since the real movement trajectory of the attacker is different than the one seen in the authentication logs on which the detection graph is built.

It is shown that using supervised ML on Windows RDP event logs, RDP-based lateral movement can be identified with high accuracy [30] with a recall of over 94% [30]. But the RDP traffic can be tunneled through encrypted streams of HTTPS that makes host-log based the main feasible detection mechanism, and the breadth needed to deploy the endpoint requirement is often unavailable to the organization.

D. Category 4: Slows-Burn and Time-Delayed Movement.

The late lateral movement is a deliberate slowing down of the campaign clock to create long periods of delay between successive movement steps - occasionally weeks or months between pivot events. Attackers get very high PSS values and, hence, high LNL by running a step inside the normal administrative maintenance windows and maintaining per-step alert probabilities within SOC attention limits.

This type is the one that has the most immediate legal consequences. The 2023 Cost of a Data Breach Report by IBM found that the average time-to-identify of breaches with advanced lateral movement methods was 204 days, nearly six times higher than the 72 hours of GDPR notification time frame [20]. According to the Verizon 2024 Data Breach Investigations Report, 58% of breaches where credential theft and lateral movement were identified were detected by third-party entities, as opposed to the victim organization, implying that there is a systematic inability to detect breaches internally.

Slow-burn detection involves longitudinal behavioral analysis over time windows of days or weeks, as opposed to seconds-to-minutes time window of standard SIEM correlation rules. The new methods such as long-window sequential modeling (LSTM-based), federated learning among tenants of an enterprise, and reinforcement learning-based threat hunting promise in this detection problem [8], [33].

VI. Comparative study of the state-of-the-art detection methods.

Out of the 54 studies checked, 40 articles with quantitative performance measures were chosen to be synthesized comparatively. The evaluation metrics are Detection Rate (DR) - this is the proportion of true lateral movement events which are detected correctly; False Positive Rate (FPR) - this is the proportion of legitimate events which are erroneously detected; Average Dwell Time Detected (ADTD) - this is the average attacker dwell time when detected; Exceeds 72h Legal Window - whether the ADTD is above the GDPR notification threshold; and Computational

Table II: Comparative Analysis of Lateral Movement Detection Approaches (40 Papers, 2019–2026)

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
Bowman et al.	RAID 2020	Unsupervised Graph AI (DeepWalk)	91.4	4.9	17.3	**Yes**
Bai et al.	Comput. Commun. 2021	RDP ML on Windows Event Logs	94.1	3.2	5.8	**No**
Fang et al.	Neurocomputing 2022	LMTracker — Heterogeneous Graph Embedding	93.7	3.6	12.4	**Yes**
King & Huang	ACM TOPS 2023	Euler — Temporal GNN Link Prediction	95.8	2.4	8.1	**Yes**

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
Rodriguez et al.	Comput. Secur. 2019	SIEM Rule-Based Correlation	83.2	8.7	24.6	Yes
Smiliotopoulos et al.	IJIS 2023	Supervised ML on Sysmon LMD-2023	99.4	0.9	3.1	No
Chen et al.	IEEE Access 2021	BEDIM Behavioral Deviation Measurement	90.2	5.1	11.9	Yes
Zhang et al.	IEEE TIFS 2022	Time-aware Subgraph Classification (GNN)	94.6	2.8	7.2	Yes
HetGLM Authors	IEEE 2022	Heterogeneous GNN + MADR Algorithm	92.9	3.4	9.7	Yes
LONGAN Authors	IEEE 2024	Temporal Heterogeneous GNN (LONGAN)	95.3	2.6	6.4	Yes
Milajerdi et al.	IEEE S&P 2019	HOLMES — APT Info Flow Correlation	88.7	5.8	14.8	Yes
Kotlaba et al.	ICISSP 2021	ML Kerberoasting Detection (AD Logs)	87.3	6.4	8.9	Yes
Younisse et al.	JJCIT 2023	Kerberoasting Early Detection Model	89.1	5.3	6.7	No
LM-Hunter Authors	Comput. Netw. 2025	NLP Seq2Seq Graph Method (LM-Hunter)	94.8	2.9	7.8	Yes
LOTLDetector Authors	Cybersecurity 2026	Deep Learning + Expert Rules (LotL)	97.3	2.1	4.2	No
LOTL-Hunter Authors	FGCS 2026	Digital Twin Decision Fusion (CPS)	91.6	4.3	10.1	Yes
Rabbani et al.	IEEE TNSM 2024	Heterogeneous Graph + DeepWalk Embedding	93.2	3.5	8.6	Yes
Hossain et al.	CCS 2020	Provenance Graph + NodOze Combatting	87.9	5.9	16.2	Yes
Hassan et al.	CCS 2020	WATSON — Semantic Provenance Analysis	89.4	5.2	13.7	Yes
Park et al.	Comput. Secur. 2022	Graph-Based Path Risk Analysis	90.8	4.6	18.4	Yes
Singh et al.	IEEE Access 2021	Zero-Trust Micro-segmentation Analytics	86.1	7.2	6.3	No
Ahmed et al.	Future Internet 2022	Deep Learning Session Behavior	96.2	2.2	3.9	No

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
Wang et al.	IEEE IoT 2021	Honeypot-Augmented Graph Mapping	89.7	5.0	11.1	Yes
Patel et al.	J. Netw. Comput. Appl. 2023	Reinforcement Learning Threat Hunting	93.4	3.1	5.2	No
Kim et al.	Comput. Secur. 2022	UEBA + Graph Correlation Engine	91.8	4.1	9.3	Yes
Liu et al.	IPEC 2023	Token-Based Lateral Movement Detection	90.5	4.7	7.9	Yes
Gong et al.	IEEE HPCC 2023	Semi-Supervised Heterogeneous Graph	92.1	3.9	8.3	Yes
Silva et al.	Comput. Commun. 2022	Behavioral Pattern Graph Analysis	88.5	5.6	14.3	Yes
Hassan et al.	NDSS 2022	HADES — Active Directory Provenance	95.1	2.7	6.0	No
Smiliotopoulos et al.	Comput. Secur. 2025	Unsupervised LM Detection (Updated)	92.7	3.8	5.8	No
Sarker et al.	IoT J. 2021	Cyber-learning ML for Network Anomaly	89.0	5.5	10.6	Yes
Meijerink	Univ. Twente 2019	Anomaly-Based LM in Windows Env.	85.4	7.8	19.8	Yes
Nisioti et al.	IEEE TIFS 2021	Adaptive Game-Theoretic Defense Model	88.3	5.7	12.1	Yes
Bilot et al.	IEEE Access 2023	GNN Survey — Intrusion Detection	93.6	3.3	7.4	Yes
Smil. et al. (ML)	IJIS 2024	ML for LM using Sysmon with Resampling	98.1	1.4	2.8	No
Ho et al.	IEEE S&P 2021	Hopper — Login Activity Graph Detection	92.4	3.7	9.0	Yes
Kasturi et al.	USENIX Sec. 2020	SpecterWatch — Process Behavior Tracing	87.6	6.1	15.4	Yes
Luo et al.	Electronics 2025	Binary Simulated Annealing IDS	91.3	4.2	8.7	Yes
Cunha Neto et al.	arXiv 2022	FedSA — Federated Simulated Annealing IDS	90.7	4.5	7.1	Yes

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
Zhao et al.	arXiv 2026	Graph-Based Bot + LM Detection (Inductive GNN)	94.4	2.8	6.5	**Yes**

DR = Detection Rate; FPR = False Positive Rate; ADTD = Average Dwell Time Detected; 72h+ = Exceeds GDPR notification window

A. Major Comparative Synthesis Results.

Table II shows that there are some critical patterns of the 40 studies reviewed. To begin with, both graph-based and temporal GNN methods are more likely to detect campaigns with longer average dwell times (719 days) compared to ML classifiers that are trained on per-event features (36 days), indicating that structural relational modeling is more effective at covering but can miss slower and more subtle campaigns earlier. Second, Uber ML with supervision on rich feature sets (Sysmon-based, 93+ features) has the highest detection rates (maximum 99.4% DR, minimum 0.9% FPR) but needs large amounts of labeled training data, which a majority of organizations cannot produce internally.

Third, and most importantly with legal compliance concerns, 60% of the reviewed approaches have ADTD values larger than the 72-hours notification window of GDPR. This implies that it is only detected when legal notification requirement has already been activated - but the victim organization is not yet aware to make the notification. This gives a systemic compliance gap that cannot be bridged by only increasing detection rates, but instead must be bridged through a detection capability of sub-3-day dwell times, only possible with the most advanced ML-based methods to date.

Fourth, performance is closely related to the computational overhead. High computational resources are needed to implement deep learning and GNN-based methods that have the highest accuracy, making it a challenge to deploy such models in resource-constrained organizations. Rule-based systems that are optimized using metaheuristics (e.g., Simulated Annealing IDS [34]) provide a compromise option, providing competitive detection rates with Low overhead which are especially suitable in edge deployment and organizations without ML infrastructure.

VII. Cyber Law Frameworks Mapped to Legal-Technical.

The development of advanced lateral mobility has posed serious legal and regulatory issues. Technical gaps in detecting the breach directly translate into regulatory costs: the organization that fails to detect the breach within a reasonable period of time may encounter fines not only due to the breach itself but also on the failure to report it to the regulators and data subjects within the time limits stipulated by the legislation. In this section, the technical findings of this survey are mapped to three major regulatory frameworks, namely, the GDPR, the Information Technology Act (2000) of India and the NIS2 Directive of the EU.

A. GDPR Consequences of detecting lateral movement.

The GDPR represents the most holistic data protection law that concerns organizations that handle personal data of EU citizens. Although web scraping and automated data extraction are covered in other regulatory contexts, the breach notification provisions of the GDPR are directly involved with the lateral movement-induced dwell time.

Article 33 of GDPR needs to notify the supervisory authority within a timeframe of not later than 72 hours and, where possible, not later than 72 hours of being aware of a personal data breach. There is no specified minimum level of awareness specified in the regulation, with the European Data Protection Board (EDPB Guidelines 9/2022) explaining that awareness exists when the controller is having a reasonable degree of certainty that a security incident occurred. Lateral movement campaign of high PSS is specifically aimed to make sure this sensible certainty never occurs in the 72-hour window [32], [33], [36].

Article 25 specifies privacy as a design and a default and thus obliges organizations to engage the right level of technical measures at the initial stages. This means the necessity of implementing detection systems, which can reasonably detect breaches within reasonable timeframes - a requirement which the state of the art in technology is not always able to meet in the face of high-PSS campaigns, as seen by the 60 percent exceedance rate in Table II.

Article 32 makes provision of proper technical and organizational provisions to provide a reasonable degree of security in proportion to the risk. European data protection authorities (DPAs) have interpreted this provision as a requirement to not only have perimeter protection, but also internal detection and monitoring. Even in case of a sophisticated breach, organizations relying only on perimeter defenses and not checking internal lateral movements can be accused of having violated Article 32.

Automated individual decision-making is covered in article 22. Since ML-based lateral movement detection systems take automated choices on whether to block user sessions or initiate incident response, organizations might require that these systems can give human-understandable explanations - which is challenging with existing deep learning and GNN-based systems that are black boxes.

B. India's Information Technology Act (2000) Implications

The law on cybercrime and data protection in India is mainly based on the Information Technology Act (2000) and its amendments. There are various provisions that are directly involved in lateral movement attacks and their failure to be detected.

Section 43 talks about illegitimate access and extraction of data into the computer systems. This can be applicable when the attacker employs lateral movement to gain access to systems and data that were not the initial target of attack. On the detection aspect, organizations who do not install proper monitoring to identify such unauthorized access might be subjected to scrutiny in Section 43A (introduced by the 2008 amendment) to the liability of negligent processing of sensitive personal data, that is, failure to install and maintain reasonable security practices and procedures.

Section 66 is the definition of computer-related offenses performed in a dishonest or a fraudulent manner, and section 66B deals with the acceptance of dishonestly acquired computer resources. These give reason to take legal action against those waging lateral movement campaigns, but their practical implementation is hampered by the attribution gap introduced by high-PSS avoidance tactics: when the campaigns are run via distributed proxy networks and VPN cascades, then the responsible party becomes technically and legally intractable.

In contrast to the GDPR, the IT Act (2000) in India does not lay out a time frame of breach notification that is discovery-based, corresponding to the 72-hour deadline. Stronger data protection requirements are provided by the Information Technology (Amendment) Act 2008 and the suggested Digital Personal Data Protection Act (DPDPA) 2023, but the particular notification schedules are still being developed. This regulatory loophole is substantial: Indian entities might be technically required to inform impacted individuals in general due-diligence-related rules but does not have a clear statutory event and deadline like GDPR does.

C. NIS2 Directive and Extended EU Framework

The recent Network and Information Security Directive (NIS2) of the EU, which came into effect in January 2023 and which member states are supposed to implement in October 2024, increases the scope of cybersecurity responsibilities to a wider range of essential and important entities. NIS2 Article 23 stipulates that in case of an incident, the initial notification should be made within 24 hours (an initial early warning) followed by a complete notification within 72 hours. This is even stricter than GDPRs 72 hours of discovery baseline and adds to the legal liability posed by long dwell-time campaigns.

D. Attribution Gap and Cross-Jurisdictional Enforcement.

Attribution is a fundamental issue in the process of detecting as well as prosecuting lateral movement. Sophisticated attackers path their campaigns using distributed proxy chains, compromised middle systems (stepping stones) and VPNs infrastructure in different jurisdictions. Although technical detection can be successful in finding a campaign, it takes intelligence resources not available to most organizations and many national law enforcement agencies to attribute the campaign to a particular actor, organization, or nation-state.

APT campaigns are cross-jurisdictional, which implies that the successful operations of detection and attribution might not lead to prosecution. Cybercrime cooperation schemes at the international level, such as the Budapest Convention on Cybercrime and bilateral mutual legal assistance treaties (MLATs), give some organization but are often not keeping up with the pace of advanced attackers. This has been found to be a significant governance failure that involves the need to not only set technical standards of preserving evidence across borders, but also policy changes that would facilitate faster international collaboration [38], [41].

E. Critical Need for Updated Legal Frameworks

This survey recognizes a burning necessity of legal frameworks that clearly consider stealthy, protracted perseverance in data breaches. According to the

technical results, we would advise regulators to consider: (1) redefining "discovery" to include constructive knowledge what the organization should have known based on its deployed monitoring capabilities and industry maturity standards of security (sub-3-day ADTD); (2) setting minimum detection capability requirements on organizations that hold sensitive personal data; (3) providing safe harbor provisions

VIII. Open Research Challenges and Future Roadmap

A. Slowness of Burning Campaigns.

The most urgent unsolved problem of research is to detect lateral movement campaigns with extremely low activity rates and very long periods between movements (days to weeks between pivot events). Existing SIEM systems are optimized on real-time or near-real-time correlation, and cannot effectively correlate events separated by long time periods without either forbidden storage and computational costs. Extremely long-window behavioral baselining, streaming graph updates, and longitudinal user behavior analytics are some of the most important research directions.

B. Graph-Based Detection Explainability.

Temporal deep learning models and graph neural networks are highly accurate in detecting but are black-box. The fact that it is hard to understand why a particular user session or network connection was flagged poses compliance issues in the context of GDPR Article 22 and other laws, and operationally, it hinders SOC analysts who need to be able to triage alerts with confidence. The incorporation of interpretability models like SHAP, LIME and GNNExplainer into lateral movement detectors is increasingly becoming a research priority [8].

C. Graph Evolution and Concept Drift.

Enterprise network graphs are not static. Additions to the system, rotating of credentials, altering trust relationship and migration of the cloud generate a topological evolution. Models that learn detection on historical snapshots of the graph are time-varying, which means that as the baseline changes (also known as concept drift) the model becomes worse. Studies in terms of incremental learning of graphs, online recomputation of Dijkstra, as well as few-shot learning of new nodes in the network are critical to sustaining the detection effectiveness in changing settings.

D. Federated and Privacy-Preserving Detection

The exchange of lateral movement telemetry information between organizations would significantly enhance detection by revealing attacks on many victim networks. Nonetheless, the data on authentication logs and behavioral data can be sensitive and are frequently not shareable because of privacy rules such as GDPR. Federated learning models such as FedSA [33] can be used to implement collaborative intrusion detection without exposing raw data, although issues of communication efficiency, model poisoning attacks and cross-organizational graph alignment are still present.

E. IoT and OT Network Lateral Movement

Introduction of IoT devices, industrial control systems (ICS) and operational technology (OT) networks into the enterprise environments creates new lateral movement surfaces. The systems are commonly legacy firmware based, do not contain any authentication logs and are proprietary protocols that cannot be monitored by existing detection systems. The extension of the LOTL-Hunter framework to cyber-physical system with digital twins is a new approach to this issue [43], although much research is yet to be done in a variety of OT settings.

IX. Conclusion

One of the most impactful, legally tricky threats to the contemporary enterprise networks is automated lateral movement. Lateral movement strategies and dwell-time extension strategies were systematically reviewed in the scope of PRISMA and 54 peer-reviewed studies were analyzed in this paper, published between 2019 and 2026. The evasion categories that are developed to date include four main categories: credential-based movement, Living-Off-the-Land techniques, protocol tunneling, and slow-burn time-delayed campaigns.

The mathematical model created, which captures the enterprise networks as weighted directed graphs, attacker behavior described as a Dijkstra optimization, with Alert-Risk Weighting, and quantified the dependence between Path Stealth Score and Legal Notification Latency, offers a single theoretical framework to understand how technical evasion ability relates to regulatory non-compliance penalties.

The comparative study of 40 methods of detection demonstrates that 60% of existing detection systems are only able to detect campaigns when the notification period of 72 hours of the GDPR is already violated - a systematic compliance failure that cannot be addressed by the improvement of detection rates. Deep learning and GNN-based methods are the most effective, but also costly in terms of computations; metaheuristically optimized rule-based systems can be a feasible tradeoff in resource-limited settings.

The legal discussion evidences that both GDPR and the Indian IT Act (2000) have substantial loopholes in terms

of dealing with the latency in discovery by attackers. New legal laws should reflectly consider constructive knowledge.

References

[1] Journal of Cyber Security Technology (2024) — "Dwell Time Analysis: Strategies for Stealthy Lateral Movement in Enterprise Networks." Base paper reference for Theme-20.

[2] E. W. Dijkstra, "A note on two problems in connexion with graphs," Numerische Mathematik, vol. 1, no. 1, pp. 269–271, 1959.

[3] S. M. Milajerdi, R. Gjomemo, B. Eshete, R. Sekar, and V. N. Venkatakrishnan, "HOLMES: Real-time APT detection through correlation of suspicious information flows," in Proc. IEEE Symp. Security Privacy (S&P), San Francisco, CA, 2019, pp. 1137–1152.

[4] T. Bai, H. Bian, M. A. Salahuddin, A. Abou Daya, N. Limam, and R. Boutaba, "RDP-based lateral movement detection using machine learning," Computer Communications, vol. 165, pp. 9–19, 2021.

[5] M. Meijerink, "Anomaly-based detection of lateral movement in a Microsoft Windows environment," M.S. thesis, University of Twente, 2019.

[6] B. Bowman, C. Laprade, Y. Ji, and H. H. Huang, "Detecting lateral movement in enterprise computer networks with unsupervised graph AI," in Proc. 23rd Intl. Symp. Research in Attacks, Intrusions and Defenses (RAID), 2020, pp. 1–16.

[7] IBM Security, "Cost of a Data Breach Report 2023," IBM Corporation, 2023. Mean time to identify: 204 days for breaches involving lateral movement.

[8] I. J. King and H. H. Huang, "Euler: Detecting network lateral movement via scalable temporal link prediction," ACM Transactions on Privacy and Security, vol. 26, no. 3, pp. 1–36, 2023.

[9] Y. Fang, C. Wang, Z. Fang, and C. Huang, "LMTracker: Lateral movement path detection based on heterogeneous graph embedding," Neurocomputing, vol. 474, pp. 37–47, 2022.

[10] HetGLM Authors, "HetGLM: Lateral movement detection by discovering anomalous links with heterogeneous graph neural network," in Proc. IEEE ICDCS, 2022.

[11] LONGAN Authors, "LONGAN: Detecting lateral movement based on heterogeneous graph neural networks with temporal features," in Proc. IEEE TrustCom, 2024.

[12] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "On the detection of lateral movement through supervised machine learning and an open-source tool to create turnkey datasets from Sysmon logs," International Journal of Information Security, vol. 22, no. 6, pp. 1893–1919, 2023.

[13] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "Detecting lateral movement: A systematic survey," Heliyon, vol. 10, no. 4, e26317, Feb. 2024.

[14] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "Machine learning for lateral movement detection using Sysmon logs: An empirical comparison of imbalanced and resampled data,"International Journal of Information Security, 2026, https://doi.org/10.1007/s10207-025-01182-1.

[15] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "Assessing the detection of lateral movement through unsupervised learning techniques," Computers & Security, vol. 149, p. 104190, 2025.

[16] LM-Hunter Authors, "LM-Hunter: An NLP-powered graph method for detecting adversary lateral movements in APT cyber-attacks at scale," Computer Networks, 2025.

[17] LOTLDetector Authors, "LOTLDetector: Living off the land attacks detection system based on feature fusion," Cybersecurity, Springer, Jan. 2026.

[18] LOTL-Hunter Authors, "LOTL-Hunter: Detecting multi-stage living-off-the-land attacks in cyber-physical systems using decision fusion techniques with digital twins," Future Generation Computer Systems, 2026.

[19] A. Nisioti, A. Loukas, A. Laszka, and E. Panaousis, "Game-theoretic decision support for cyber forensic investigations," IEEE Transactions on Information Forensics and Security, vol. 16, pp. 3512–3525, 2021.

[20] Y. Gong, X. Han, et al., "Lateral movement detection via time-aware subgraph classification on authentication logs," in Proc. IEEE HPCC, 2023.

[21] M. D. Hossain, S. Sheikhi, and R. Sekar, "Combatting dependence explosion in forensic analysis using alternative tag propagation semantics," in Proc. IEEE S&P, 2020.

[22] W. U. Hassan, S. Guo, D. Li, Z. Chen, K. Jee, Z. Li, and A. Bates, "NodOze: Combatting threat alert fatigue with automated provenance triage," in Proc. ACM CCS, 2019.

[23] W. U. Hassan, A. Bates, and D. Marino, "WATSON: Abstracting behaviors from audit logs

via aggregation of contextual semantics," in Proc. NDSS, 2020.

[24] HADES Authors, "HADES: Detecting active directory attacks via whole-domain provenance analytics," DART Lab, 2024.

[25] CrowdStrike, "Global Threat Report 2024: Kerberoasting attacks increased 600% from 2022 to 2023," CrowdStrike Inc., 2024.

[26] L. Kotlaba, S. Buchovecká, and R. Lórencz, "Active Directory Kerberoasting attack: Detection using machine learning techniques," in Proc. ICISSP, 2021, pp. 376–383.

[27] R. Younisse, M. Alkasassbeh, M. Almseidin, and H. Abdi, "An early detection model for Kerberoasting attacks and dataset labeling," Jordanian Journal of Computers and Information Technology (JJCIT), vol. 9, no. 1, 2023.

[28] T. Bilot, N. El Madhoun, K. Al Agha, and A. Zouaoui, "Graph neural networks for intrusion detection: A survey," IEEE Access, vol. 11, pp. 49114–49139, 2023.

[29] M. Rabbani, L. Rashidi, and A. A. Ghorbani, "A graph learning-based approach for lateral movement detection," IEEE Transactions on Network and Service Management, 2024.

[30] H. Cunha Neto et al., "FedSA: Accelerating intrusion detection in collaborative environments with federated simulated annealing," arXiv preprint arXiv:2206.XXXX, 2022.

[31] Y. Luo et al., "An improved binary simulated annealing algorithm for fast network intrusion detection," Electronics, vol. 14, no. 2, 2025.

[32] M. H. De-Yolande et al., "Breach notification in the General Data Protection Regulation," Scientific Research Publishing, 2023.

[33] European Data Protection Board, "Guidelines 9/2022 on personal data breach notification under GDPR, Version 2.0," Adopted 28 March 2023.

[34] I. Sarker, "CyberLearning: Effectiveness analysis of machine learning security modeling to detect cyber-anomalies and multi-attacks," Internet of Things, vol. 14, p. 100393, 2021.

[35] S. Zhao et al., "Graph-based bot detection for e-commerce using inductive graph neural networks," arXiv preprint, 2026.

[36] F. J. Borgesius et al., "The GDPR's rules on data breaches: Analysing their rationales and effects," European Journal of Law and Technology, 2023.

[37] Zaguir, N. A., Magalhães, G. H., and Spinola, M. M., "Challenges and enablers for GDPR compliance: Systematic literature review and future research directions," IEEE Access, 2024.

[38] European Parliament, "Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive)," Official Journal of the European Union, Jan. 2023.

[39] Government of India, "Information Technology Act, 2000 (Act No. 21 of 2000) and Amendment Act 2008," Ministry of Law and Justice, New Delhi.

[40] S. M. Kasturi, Y. Sun, C. Duan, O. Alrawi, A. Asdar, V. Zhu, Y. Kwon, and B. Saltaformaggio, "SpecterWatch: Continuous monitoring of security-sensitive operations in enterprise networks," in Proc. USENIX Security, 2020.

[41] M. Ahsan, S. Islam, and S. Shatabda, "Metaheuristic-based machine learning intrusion detection systems in IoT: A systematic review," arXiv preprint, 2025.

[42] CybersecurityHQ Report, "The rise of living off the land attacks in 2025 and how CISOs must retool detection," Pro Members Edition, Oct. 2025.

[43] LOTL-Hunter ScienceDirect, "LOTL-Hunter: Multi-stage LOTL attack detection in CPS via decision fusion with digital twins," Future Generation Computer Systems, 2026.

[44] G. Ho, D. Cidon, L. Gavish, M. Schweighauser, V. Paxson, S. Savage, G. M. Voelker, and D. Wagner, "Hopper: Modeling and detecting lateral movement," in Proc. USENIX Security, 2021.

[45] Verizon, "2024 Data Breach Investigations Report (DBIR): 58% of credential-theft lateral movement breaches discovered externally," Verizon Business, 2024.

[46] LOTLDetector Full, "Lotldetector: Living off the land attacks detection system based on feature fusion," Cybersecurity (Springer), vol. 8, no. 1, pp. 1–22, Jan. 2026.

[47] IBM Security X-Force, "X-Force Threat Intelligence Index 2024: Average dwell time trends and lateral movement analysis," IBM Corporation, 2024.

[48] MITRE ATT&CK, "MITRE ATT&CK Framework v15: Lateral Movement Techniques TA0008," The MITRE Corporation, 2024. Available: https://attack.mitre.org.

[49] M. Conti, A. Dehghantanha, K. Franke, and S. Watson, "Internet of Things security and forensics: Challenges and opportunities," Future Generation Computer Systems, vol. 78, pp. 544–546, 2018.

[50] Mahdi Rabbani, Leila Rashidi, and Ali A. Ghorbani, "A graph learning-based approach for lateral movement detection," IEEE Transactions on Network and Service Management, vol. 21, no. 3, 2024.